

CERA Medical Developer 03 Platform Security and Release

Ten day execution manual with feature ownership and Git commands

Use this manual together with the CERA Medical Product Requirements Document

Document	Value
Owner	Stack & Scale for CERA Medical
Version	1.0
Date	17 September 2026
Status	Approved implementation baseline subject to CERA content and release approval

Own the repository controls, environments, Docker and Caddy platform, Authentik, R2, CI/CD, monitoring, backups, release approval, and rollback.

1 Role boundaries

Item	Working rule
Primary mission	Own the repository controls, environments, Docker and Caddy platform, Authentik, R2, CI/CD, monitoring, backups, release approval, and rollback.
Review relationship	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.
Integration branch	develop. It deploys to staging after required checks.
Production branch	main. Only approved release or hotfix pull requests may merge.
Daily evidence	Pushed branch, updated issue, tests, PR or staging link, and explicit next handoff.
Non-negotiable	Never commit secrets or production data; never push directly to develop or main; never disable authorization, tests, backups, or release controls to meet schedule.

2 Owned feature catalogue

ID	Feature	Acceptance evidence	Day	Dependencies
FND-001	Repository and monorepo foundation	Fresh clone installs and all workspace commands run; no secret or generated artifact is tracked.	Day 1	None
FND-002	Local service stack	A new developer follows README steps and reaches all local health endpoints within 30 minutes.	Day 1	FND-001
FND-004	Continuous integration checks	Required checks report independently and a failing required check blocks merge.	Day 2	FND-001
FND-005	Environment contract	The repository contains .env.example files with placeholders; real values exist only in approved secret stores.	Day 2	FND-001
AUTH-501	Authentik identity provider	Staging login, logout, token validation, session expiry, and admin MFA are verified with test accounts.	Day 3	FND-005

ID	Feature	Acceptance evidence	Day	Dependencies
AUTH-502	Role based access control	Automated authorization tests prove each role can only access approved routes, records, and actions.	Day 3-4	AUTH-501
INT-803	Cloudflare R2 media storage	Upload, replace, delete, render, cache, file-type, and file-size rules work in staging; bucket credentials are not exposed to clients.	Day 4	CMS-101, FND-005
INF-901	Caddy and Cloudflare edge	Only ports 80 and 443 are public; database and cache ports are private; health checks and forwarded headers work.	Day 4	FND-002
INF-902	Staging deployment	A successful merge updates staging without manual file copying; a failed health check restores the previous image.	Day 5	FND-004, INF-901
INF-903	Production deployment	Production secrets are unavailable before approval; deployment records version, approver, image digest, migration, and rollback target.	Day 10	INF-902, REL-1101
INF-904	Backup and restore	The team restores a staging database from backup and records recovery time and integrity checks before launch.	Day 6	FND-002
OBS-1001	Monitoring and error reporting	A deliberate staging error reaches the correct project without secrets or personal message content.	Day 7	INF-902
QA-1101	Automated release test suite	Required checks pass from a clean clone; failures are reproducible locally; test fixtures contain no real customer data.	Day 8	All build features
REL-1101	CERA user acceptance testing	Every launch-blocking defect is closed; lower-priority defects have an owner and accepted follow-up date; approvals are recorded.	Day 9	QA-1101
REL-1102	Release and rollback	The release checklist, change log, rollback reference, and ownership handover are complete.	Day 10	REL-1101, INF-903
DOC-1201	Operations handover	A named CERA owner can execute routine content and enquiry tasks without developer assistance.	Day 10	REL-1102

3 Daily Git routine

3.1 Start every morning

First protect any unfinished local work. Then update develop and merge it into the active feature branch. This project does not require rebasing shared branches, so developers do not need force push.

```
git status
# If needed: git stash push -u -m "WIP before morning sync"
git fetch --prune origin
git switch develop
git pull --ff-only origin develop
git switch <your-feature-branch>
git merge --no-edit develop
# If used: git stash pop
pnpm install --frozen-lockfile
pnpm lint
pnpm typecheck
pnpm test
```

3.2 Start the assigned branch

```
git fetch --prune origin
git switch develop
git pull --ff-only origin develop
git switch -c <branch-from-the-daily-plan>
```

3.3 Commit and push

```
git status
git diff
git add -p
git diff --cached
git commit -m "<type>(<scope>): <specific result>"
git push -u origin $(git branch --show-current)
```

3.4 Open the pull request

```
gh pr create \
  --base develop \
  --head $(git branch --show-current) \
  --title "<type>(<scope>): <specific result>" \
  --body-file .github/pull_request_template.md
gh pr checks --watch
gh pr view --web
```

3.5 Resolve conflicts

```
git status
# Edit conflicted files and remove every conflict marker.
git diff --check
git add <resolved-files>
git commit
pnpm lint && pnpm typecheck && pnpm test
git push
# To cancel before commit: git merge --abort
```

3.6 Review and cleanup

```
gh pr checkout <PR_NUMBER>
pnpm install --frozen-lockfile
pnpm lint && pnpm typecheck && pnpm test && pnpm build
gh pr review <PR_NUMBER> --approve
# Maintainer after approval and green checks:
gh pr merge <PR_NUMBER> --squash --delete-branch
git switch develop
git pull --ff-only origin develop
git branch -d <merged-feature-branch>
git fetch --prune origin
```

4 Ten day feature plan

Day 1

Branch	Feature IDs	Reviewer
chore/cera-301-platform-bootstrap	FND-001, FND-002	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Create the CERA-owned repository structure, local Compose stack, health endpoints, private networks, least-privilege users, and base server runbook.

Done evidence. A clean clone starts locally and no database or cache port is exposed beyond the intended development host.

Required handoff. Publish local service addresses and health checks to Dev 1 and Dev 2.

Day 2

Branch	Feature IDs	Reviewer
ci/cera-302-quality-gates	FND-004, FND-005	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Configure GitHub rulesets, CODEOWNERS, Actions permissions, pinned actions, CI jobs, environment contracts, and staging/production GitHub environments.

Done evidence. Required checks block a test PR and branch protections prevent direct pushes and force pushes.

Required handoff. Make required check names stable before rulesets require them.

Day 3

Branch	Feature IDs	Reviewer
feat/cera-303-authentik-oidc	AUTH-501, AUTH-502	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Deploy Authentik for staging, configure OIDC clients, roles, admin MFA, recovery email, trusted proxies, and test accounts.

Done evidence. Login, logout, token validation, role claims, expired sessions, and admin MFA pass in staging.

Required handoff. Give Dev 1 login details and Dev 2 token claim examples.

Day 4

Branch	Feature IDs	Reviewer
feat/cera-304-edge-r2	INT-803, INF-901	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Configure Cloudflare DNS, R2 buckets and tokens, Caddy HTTPS/reverse proxy, security headers, upload limits, and private service networks.

Done evidence. Staging uses HTTPS, media uploads work, and only approved public endpoints are reachable externally.

Required handoff. Confirm media path with Dev 1 and network paths with Dev 2.

Day 5

Branch	Feature IDs	Reviewer
feat/cera-305-staging-deploy	INF-902	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Build and publish immutable GHCR images, deploy develop to CX33 staging, run controlled migrations and health checks, and record image digests.

Done evidence. A merged test PR deploys automatically and a forced health failure rolls back to the previous image.

Required handoff. Give the team the staging URL and deployment evidence format.

Day 6

Branch	Feature IDs	Reviewer
feat/cera-306-backup-restore	INF-904	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Enable Hetzner backups, encrypted PostgreSQL dumps to off-server storage, retention, restore scripts, and configuration recovery documentation.

Done evidence. A staging restore succeeds and measured recovery time and integrity evidence are recorded.

Required handoff. Run restore with Dev 2 and record the measured result.

Day 7

Branch	Feature IDs	Reviewer
feat/cera-307-glitchtip-observability	OBS-1001	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Deploy self-hosted GlitchTip, configure release-tagged projects, structured logs, uptime checks, disk and backup alerts, and alert routing.

Done evidence. Deliberate errors reach the correct projects without secrets or personal enquiry text.

Required handoff. Ask each developer to verify a deliberate error and release tag.

Day 8

Branch	Feature IDs	Reviewer
test/cera-308-security-release	QA-1101	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Run access, secret, dependency, container, firewall, headers, rate-limit, session, backup, and disaster-recovery checks.

Done evidence. The release security checklist is approved or has named blocking issues; no critical or high unresolved finding remains.

Required handoff. Record every blocking finding in GitHub with owner and severity.

Day 9

Branch	Feature IDs	Reviewer
fix/cera-309-uat-release	REL-1101	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Support UAT fixes, freeze platform changes, prepare release branch, validate production configuration, and confirm rollback owner and command.

Done evidence. Production approval checklist is ready for CERA and every release secret is present in the correct environment.

Required handoff. Accept only release-critical changes after the freeze.

Day 10

Branch	Feature IDs	Reviewer
release/cera-310-production-v1	INF-903, REL-1102, DOC-1201	Dev 1 reviews public routes and smoke tests. Dev 2 reviews migration, database, worker, and integration runtime requirements.

Build work. Approve the production workflow, deploy v1.0.0 to CX43, run smoke tests, monitor 24 hours, and transfer access and runbooks.

Done evidence. Release record, image digest, tag, approvals, backup status, rollback reference, and handover are complete.

Required handoff. Transfer access, monitoring, deployment, backup, and incident runbooks.

5 Daily completion checklist

- Issue is assigned, in the correct status, and has current acceptance criteria.
- Branch name matches this manual and starts from the latest develop.
- Changes are focused, self-reviewed, and contain no secret or real customer data.
- Relevant lint, type check, unit, integration, browser, build, migration, or infrastructure checks pass.
- PR links the issue and includes testing, screenshots where relevant, environment changes, migration impact, and rollback behavior.
- Reviewer feedback is resolved and required approvals apply to the latest push.
- Merged behavior is verified in staging and evidence is linked to the issue.
- The next developer receives an explicit contract, URL, fixture, command, or blocker before the day ends.

6 Escalation and schedule protection

- Raise a blocker in the 09:30 stand-up and in the GitHub Issue. Do not wait until the end of the day.
- If an external service is unavailable, use the agreed mock adapter and keep the real integration issue open with an owner.
- If a task is too large, split a complete vertical slice into a new PR. Keep incomplete behavior disabled.
- After Day 8, accept only UAT defects, security fixes, release documentation, and changes required to launch safely.
- A security, authorization, data-loss, migration, backup, or rollback blocker stops release even if the calendar target is at risk.

7 Assignment confirmation

Named developer	Date assigned	Developer acknowledgement	Technical lead